

## CYB 240 Project Two Scenario One

You are a newly hired analyst for a health insurance company with a central office and several satellite offices. The central office administers all back-end servers and pushes out all communications to satellite offices via a web interface. The organization has requested that a security analyst participate in a new web application development from the start of the project to advise on possible security risks. The application is used only by internal employees as an interface with the patient information system.

A member of the IT team has reviewed the design documents for the new development project and has provided the following list of system specifications.

Three-tiered system:

- MySQL Database
  - Existing system specifications:
    - Proper authentication to access data in table
    - Communication with transaction server done through PHP
- Microsoft Transaction Server
  - Existing system specifications:
    - Transaction server has administrative access to MySQL database
    - Communication to the database is done over company network
    - Communication to the web server front end is done over the internet
    - Components sent to web server front end are in XML format with weak metadata
    - Transactions sent to web server are unencrypted and 1-1 (not batched)
- Web Server Front End
  - Existing system specifications:
    - Data displayed on webpages is in clear text using HTTP protocols
    - Log-on access to web server is via client-side scripting